SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad İlayda ŞENOCAK | Grup B Sabah | Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)
   Üç şarta bakarım. Component X 2.4, presin PLC firmware'inde var mı (SBOM'dan kontrol), 2.4 sürümü CVE'nin etkilenen aralığında mı, zafiyetli kısma ağdan ya da uzak erişimden ulaşılabiliyor mu. Üçü de evetse bizi etkiler. Biri hayırsa acil değildir, izlemeye alırım.
2. Üretimi hemen durdurur musunuz? Neden / neden değil?
   Hayır, durdurmam. Önce üç şartı doğrularım, çünkü plansız durdurma ve plansız yama da risk yaratır. Yamayı planlı bakım zamanında uygularım. Sömürüldüğüne dair belirti varsa presi ağdan ayırır, gerekirse durdururum.
3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?
   Önce test. Üretimdeki presi denemem, yedek PLC ya da simülasyonda denerim. Sonra yedek alıp geri dönüş planıyla bakım zamanında uygularım.
4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?
   Etkileyebilir, çünkü firmware presin safety yapısına dokunur. Üreticinin yama notlarına bakarım: safety bileşeni, sertifika ya da checksum değişiyor mu. Yamadan sonra E-stop, ışık perdesi ve STO'yu yeniden test ederim.
5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?
   Presin ağını ayırırım, uzak erişimi kapatırım ya da yalnızca jump server ve MFA ile açarım. Sadece izinli cihazlara izin veririm, trafiği izleyip değişiklikte alarm kurarım. Bakım laptopunu ve makineye fiziksel erişimi de denetlerim.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.